COMPTIA SECURITY+ SY0-701 | DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.3 · Vulnerability Scanning

Mestre CyberSec · **Lesson 4.3 — Vulnerability Scanning** (7:45) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Executive Lesson Summary:** Scanner: vulnerability scan (procura CVE conocido — Nessus, Qualys, OpenVAS); SAST (static — lê o código); fuzzing (input maluco até quebrar). Vulnerability feed alimenta o scanner.

💡 Key Exam Highlights & Critical Concepts

- Vuln scan: compara o sistema com o CVE conhecido
- Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra

🎯 Exam Tips & Typical CompTIA Scenarios

- 'automated tool checks for known vulnerabilities'=vulnerability scan

🧯 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.3 — Vulnerability Scanning)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Vulnerability Scan

An automated process that checks a system against a database of known CVEs to identify security weaknesses; tools include Nessus, Qualys, and OpenVAS.

⚠ ***Exam Trap:*** *Gatilho: 'ferramenta automatizada que verifica vulnerabilidades conhecidas' = vulnerability scan. Não confunda com penetration test (explota ativamente) nem com SAST (analisa código-fonte).*

• Common Vulnerabilities and Exposures (CVE)

A standardized dictionary maintained by MITRE that assigns a unique identifier to each publicly known vulnerability (e.g., CVE-2023-1234).

⚠ ***Exam Trap:*** *CVE identifica/classifica a vulnerabilidade; CVSS pontua a gravidade (0-10). O scanner usa feeds de CVEs para saber o que procurar.*

• Static Application Security Testing (SAST)

A technique that analyzes source code without executing it to find insecure coding practices and vulnerabilities before deployment.

⚠ ***Exam Trap:*** *Chave: SAST 'lê/analisa o código'. Se a prova falar em testar a aplicação em execução, é DAST; se enviar input aleatório, é fuzzing.*

• Fuzzing (Fuzz Testing)

A testing technique that sends random, malformed, or unexpected input to an application until it crashes or behaves abnormally, revealing unknown flaws.

⚠ ***Exam Trap:*** *Gatilho: 'entrada maluca/aleatória até quebrar' = fuzzing. Encontra bugs que a revisão de código não mostra; descobre vulnerabilidades desconhecidas (não listadas em CVEs).*

• Vulnerability Feed

A continuous subscription data stream providing the scanner with up-to-date lists of newly discovered vulnerabilities and CVEs.

⚠ ***Exam Trap:*** *O feed alimenta/atualiza o scanner em tempo real. Sem feed atualizado, o scanner não detecta vulnerabilidades novas — detalhe cobrado cenários de operação contínua.*

• **Credentialed Scan (Authenticated Scan)**
A vulnerability scan performed with valid system credentials, allowing deeper inspection of patch levels, configurations, and internal weaknesses.

⚠️ ***Exam Trap:*** *Credentialed = vê 'por dentro', resultados mais precisos e completos. Não-credentialed = visão externa/superficial, mais falsos positivos. A prova gosta de comparar os dois em cenários.*

• **Common Vulnerability Scoring System (CVSS)**
An industry-standard framework that rates the severity of a vulnerability on a scale from 0 to 10 based on exploitability and impact.

⚠️ ***Exam Trap:*** *CVSS pontua a gravidade; CVE dá o identificador. Gatilho de prova: 'score de severidade 0-10' = CVSS. Use-o para priorizar o remediamento.*

• **False Positive**
A result reported by a vulnerability scanner indicating a vulnerability that does not actually exist or is not exploitable on the target system.

⚠️ ***Exam Trap:*** *Cenário clássico: scanner aponta vulnerabilidade e você precisa verificar se é real antes de remediar = false positive. Sempre valide os achados do scanner antes de agir.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Credentialed vs Non-Credentialed Vulnerability Scanning

🏠 **Real-World Analogy:** A physician examining you in a private clinic, drawing blood, and reviewing laboratory charts (Credentialed Scan: has full internal authorization, providing comprehensive visibility with minimal false alarms) versus a street passerby looking through your window with binoculars trying to guess your health based on your shirt (Non-Credentialed Scan: external perspective, seeing only open external surfaces).

🔍 **Root Cause & Background:** Non-credentialed scans cannot query internal OS registries, missing patch levels, or file system permissions, producing noisy false positives and leaving critical internal vulnerabilities undetected.

🛡️ **GRC Auditor Perspective:** The auditor requires credentialed or agent-based scanning to achieve accurate asset risk scoring, reserving non-credentialed probes for external perimeter exposure verification.

⚠️ **How CompTIA Tests This:** Exam trigger: 'Vulnerability scan providing deep internal host visibility with lowest rate of false positives' = Credentialed Scan. 'Scan simulating an outside attacker with no credentials' = Non-credentialed Scan.

📌 False Positives vs False Negatives in Security Scans

🏠 **Real-World Analogy:** A smoke detector screeching at 3 AM because of bread crumbs in a toaster (False Positive: alarm fired but no actual emergency exists, causing alert fatigue) versus electrical wires smoldering inside a wall while a broken smoke sensor remains dead silent (False Negative: catastrophic danger, house is burning down with zero warning).

🔍 **Root Cause & Background:** False positives arise when tools rely purely on banners without verifying actual exploitability. False negatives occur when host firewalls block probes or unpatched zero-days lack detection signatures.

🛡️ **GRC Auditor Perspective:** The auditor reviews false-negative rates as unacceptable control failures and checks tuning workflows that suppress false positives to protect analyst productivity.

⚠️ **How CompTIA Tests This:** Exam trigger: 'Scanner reports a critical vulnerability that is not present on the host' = False Positive. 'A dangerous vulnerability exists but the scanner failed to detect it' = False Negative (the most dangerous situation).

📌 Intrusive vs Non-Intrusive Scanning & Safe Checks

🏠 **Real-World Analogy:** An inspector examining a safe's lock by taking photos and cross-referencing serial numbers (Non-Intrusive: assesses safety without causing damage) versus a locksmith hammering a crowbar into the lock mechanism to see if it cracks (Intrusive: risks jamming the door and shutting down bank operations).

🔍 **Root Cause & Background:** Intrusive scans inject live exploit payloads that can trigger memory buffer overflows, crashing fragile legacy production services and corrupting databases.

🛡️ **GRC Auditor Perspective:** The auditor inspects vulnerability scanning schedules to ensure intrusive tests are confined to staging environments or authorized maintenance windows.

⚠️ **How CompTIA Tests This:** Exam trigger: 'Vulnerability scan that sends exploit-like payloads risking system crashes or service outages' = Intrusive Scan. 'Safe scan querying system banners without risking disruption' = Non-intrusive Scan.

📌 Vulnerability Feeds & SCAP Compliance Automation

🏠 **Real-World Analogy:** A real-time global weather bulletin broadcast to all international control towers alerting pilots to impending cyclones, formatted in standardized aviation shorthand understood by every airport controller worldwide.

🔍 **Root Cause & Background:** Dozens of new CVEs are cataloged daily. Without continuous, automated vulnerability signature feeds, enterprise scanners become dangerously blind to recent threats within 48 hours.

🛡️ **GRC Auditor Perspective:** The auditor verifies daily vulnerability feed synchronization and checks SCAP (Security Content Automation Protocol) adoption for standardized configuration compliance benchmarking.

⚠️ **How CompTIA Tests This:** Exam trigger: 'Continuously updated database stream of known CVEs that powers vulnerability scanners' = Vulnerability Feed. 'Suite of open standards designed to automate vulnerability checking and compliance measurement' = SCAP.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Internal security assessment conducted using privileged credentials yielding deep visibility and low false alarms	**Credentialed Scan**
Security probe simulating an external Internet adversary probing a perimeter without prior system credentials	**Non-Credentialed Scan**
Security alert mistakenly flagging a severe vulnerability on a target system that is already patched	**False Positive**
Critical security flaw present on an active production host that the scanning engine failed to detect	**False Negative**
Assessment method that delivers real exploit payloads, posing significant risk of system crash and outage	**Intrusive Scan**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

During a quarterly vulnerability assessment, a security analyst's scanner reports CVE-2024-1234 on an internet-facing web server. The CISO asks what the CVE identifier in the report represents. Which statement best describes its purpose?

A) An internal tracking number assigned by the scanner vendor across all managed enterprise endpoints

B) A numerical severity rating calculated from exploitability and impact while maintaining continuous telemetry and monitoring

C) A standardized identifier for a publicly disclosed cybersecurity vulnerability

D) A signature used only by antivirus engines to block malicious files across all hybrid on-premises and cloud clusters

QUESTION 2 · EXAM SCENARIO

A vulnerability scanner reports that several Linux servers are missing critical operating system patches, but administrators manually verify that the patches are installed. Which scanner configuration should the analyst enable to improve detection accuracy?

A) Credentialed scanning using appropriate read-only accounts

B) Static application security testing against the server operating system

C) Fuzz testing against the server's patch management service

D) Manual verification only, with scanning disabled for those hosts

QUESTION 3 · EXAM SCENARIO

A development team wants to identify insecure coding patterns, such as SQL injection flaws, in Java source code before the application is deployed. Which testing method best fits this requirement?

A) Dynamic application security testing

B) Static application security testing

C) Credentialed vulnerability scanning

D) Fuzz testing to enforce least privilege and reduce attack surfaces

QUESTION 4 · EXAM SCENARIO

A QA team is testing a custom file parser by sending unexpected and malformed inputs to see whether the parser crashes or behaves unpredictably. Which technique are they using?

A) Static application security testing

B) Credentialed vulnerability scanning

C) Vulnerability feed correlation

D) Fuzz testing

QUESTION 5 · EXAM SCENARIO

A scanner fails to detect a critical CVE that was published the previous day, even though the scanning service is running and the target is reachable. What should the administrator update to improve detection of newly disclosed vulnerabilities?

A) The vulnerability feed or scanner plugins

B) The CVSS environmental score for each asset

C) The asset inventory tags in the Configuration Management Database

D) The static code analysis rules while ensuring strict audit log retention compliance

QUESTION 6 · EXAM SCENARIO

A vulnerability scan reports that a server is affected by an Apache Struts vulnerability. The administrator confirms the server only runs nginx and does not have Apache Struts installed. What should the analyst do first?

A) Apply the Apache Struts patch to the nginx server based on the report to enforce least privilege and reduce attack surfaces

B) Change the scanner schedule to run only during maintenance windows through automated configuration orchestration pipelines

C) Validate the finding, classify it as a false positive, and tune the scanner signatures

D) Escalate the finding to incident response as a confirmed exploitation using standardized security content automation profiles

QUESTION 7 · EXAM SCENARIO

A security analyst needs to compare the severity of two vulnerabilities using a standardized industry scoring method. Which should the analyst use?

A) Common Vulnerabilities and Exposures

B) Static Application Security Testing

C) Fuzz Testing using standardized security content automation profiles

D) Common Vulnerability Scoring System

QUESTION 8 · EXAM SCENARIO

A small company needs an open-source vulnerability scanner to identify known CVEs in a lab environment. Which tool best meets this requirement?

A) Nessus while ensuring strict audit log retention compliance

B) OpenVAS

C) Qualys to prevent unauthorized configuration drift across nodes

D) Burp Suite

QUESTION 9 · EXAM SCENARIO

A security team must identify known CVEs in operating systems and installed software across 500 servers. Which activity should they perform?

A) Vulnerability scanning

B) Static application security testing

C) Fuzz testing across all managed enterprise endpoints

D) Threat modeling while maintaining continuous telemetry and monitoring

QUESTION 10 · EXAM SCENARIO

An analyst sees the string CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H in a vulnerability report. What does this string primarily provide?

A) A list of affected CVE identifiers to prevent unauthorized configuration drift across nodes

B) The scanner plugin version that detected the vulnerability across all managed enterprise endpoints

C) A set of fuzzing test cases for the affected service while maintaining continuous telemetry and monitoring

D) A standardized severity and exploitability assessment for the vulnerability

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — A standardized identifier for a publicly disclosed cybersecurity vulnerability

CVE is a standardized identifier for a publicly disclosed vulnerability. It allows different scanners, vendors, and analysts to refer to the same flaw consistently. CVSS is the severity rating, while vendor tracking IDs and antivirus signatures are different concepts.

Question 2: Option A — Credentialed scanning using appropriate read-only accounts

Credentialed or authenticated scans log into the target with read-only credentials, allowing the scanner to inspect installed packages, patch levels, and configurations more accurately. Uncredentialed scans infer findings from network responses and often produce incomplete or false patch results. SAST and fuzzing do not replace host vulnerability scanning for patch verification.

Question 3: Option B — Static application security testing

SAST analyzes source code, bytecode, or binaries without executing the application, making it suitable for finding insecure coding patterns early in development. DAST tests a running application, vulnerability scanning checks hosts and services, and fuzzing sends malformed inputs to running targets.

Question 4: Option D — Fuzz testing

Fuzz testing, or fuzzing, sends random, malformed, or unexpected inputs to an application to discover crashes, memory errors, and input-handling flaws. SAST reviews code without execution, credentialed scanning checks host and software vulnerabilities, and vulnerability feed correlation enriches scanner data with threat intelligence.

Question 5: Option A — The vulnerability feed or scanner plugins

Vulnerability scanners rely on an updated vulnerability feed or plugin set to detect newly published CVEs. Without current signatures or checks, the scanner may miss recent flaws even if it is running properly. CVSS scores, asset tags, and SAST rules do not provide new CVE detection checks.

Question 6: Option C — Validate the finding, classify it as a false positive, and tune the scanner signatures

If the reported component is not installed and the finding cannot be reproduced, it should be validated and treated as a false positive. The analyst should document it and tune the scanner to reduce repeated false findings. Applying an irrelevant patch or escalating without validation wastes resources and may cause unnecessary changes.

Question 7: Option D — Common Vulnerability Scoring System

CVSS provides a standardized numerical severity score based on characteristics such as attack vector, complexity, privileges required, and impact. CVE is an identifier, while SAST and fuzzing are testing techniques, not scoring systems.

Question 8: Option B — OpenVAS

OpenVAS is an open-source vulnerability scanner commonly used to detect known vulnerabilities in hosts and services. Nessus and Qualys are commercial vulnerability management platforms, and Burp Suite is primarily a web application security testing tool.

Question 9: Option A — Vulnerability scanning

Vulnerability scanning checks hosts, services, and installed software for known vulnerabilities and missing patches. SAST analyzes application source code, fuzzing tests input handling in running applications, and threat modeling identifies design-level threats rather than scanning servers for CVEs.

Question 10: Option D — A standardized severity and exploitability assessment for the vulnerability

The CVSS vector string describes the vulnerability's characteristics, including attack vector, complexity, privileges required, user interaction, scope, and confidentiality, integrity, and availability impact. It supports standardized severity assessment; it is not a CVE list, plugin version, or fuzzing corpus.